

Plantilla de Excel para Cálculo de IGM y ROI

Esquema de implementación

1. Estructura general del libro de Excel

Se recomienda crear un libro con, al menos, las siguientes hojas:

1. Respuestas – vuelco de las respuestas de la encuesta, una fila por organización.
2. Codificación – tabla de mapeo de respuestas textuales a valores numéricos.
3. IGM_TRIKE – cálculo de subíndices (T, R, I, K, E) e índice global de madurez.
4. ROI – modelo de coste/beneficio y estimaciones de retorno.
5. Parametros – pesos, umbrales y supuestos ajustables.

2. Codificación de respuestas

En la hoja Codificación, definir para cada pregunta una escala (0–4) donde:

- 0 represente ausencia de práctica o nivel mínimo.
- 4 represente un nivel de madurez alto, sistemático y evidenciable.

Ejemplo (simplificado):

Pregunta	Respuesta	Valor
P1.4	Nunca	0
P1.4	Muy raramente / casi nunca	1
P1.4	Ocasionalmente	2
P1.4	Sí, pero solo en proyectos críticos	3
P1.4	Sí, sistemáticamente en todos los proyectos relevantes	4

La misma lógica puede aplicarse al resto de preguntas cerradas.

3. Cálculo de subíndices TRIKE

En Parametros, definir:

- Conjunto de preguntas por dimensión:
- Threat (T): P1.1–P1.8
- Risk (R): P2.1–P2.6
- Impact (I): P3.1–P3.6
- Knowledge (K): P4.1–P4.5
- Evaluation (E): P5.1–P5.6, P6.1–P6.3

Para cada organización (fila) en Respuestas:

- Traducir respuestas textuales a valores numéricos mediante búsquedas (por ejemplo, BUSCARV o XLOOKUP).
- Calcular la media o suma normalizada de los valores de cada grupo de preguntas.

Ejemplo de fórmula (pseudo):

- $T = \text{PROMEDIO}(P1.1_valor; P1.2_valor; \dots; P1.8_valor)$
- $R = \text{PROMEDIO}(P2.1_valor; \dots; P2.6_valor)$
- etc.

Normalizar opcionalmente a una escala 0–100:

- $T_norm = (T / 4) * 100$
- $R_norm = (R / 4) * 100$
- etc.

El Índice Global de Madurez (IGM) puede definirse como:

- $$IGM = (wT * T_norm + wR * R_norm + wI * I_norm + wK * K_norm + wE * E_norm) / (wT + wR + wI + wK + wE)$$

donde wT , wR , etc., son pesos configurables en Parametros.

4. Modelo básico de ROI

En la hoja ROI, se sugiere:

4.1 Variables de entrada (por organización)

- Coste_CS: gasto anual en ciberseguridad (personal, tecnología, servicios).
- Incidentes_previos: número de incidentes con impacto significativo en periodo de referencia.
- Coste_total_incidentes_previos: estimación total de impacto económico en dicho periodo.
- Incidentes_actuales: número de incidentes tras implementación de medidas.
- Coste_total_incidentes_actuales: coste asociado.
- Ingresos_anuales o Valor_activos_críticos.

4.2 Indicadores derivados

- $\text{Reducción_incidentes} = \text{Incidentes_previos} - \text{Incidentes_actuales}$
- $\text{Reducción_coste} = \text{Coste_total_incidentes_previos} - \text{Coste_total_incidentes_actuales}$
- $\text{Ratio_reducción} = \text{Reducción_coste} / \text{Coste_total_incidentes_previos}$ (cuando aplicable)

4.3 ROI simplificado

Un modelo básico de ROI:

- $$ROI_CS = (\text{Reducción_coste} - \text{Coste_CS}) / \text{Coste_CS}$$

Interpretación:

- $ROI > 0$: la reducción de pérdidas por incidentes supera el coste de las medidas de ciberseguridad.
- $ROI \approx 0$: equilibrio (no se pierde, pero tampoco se gana en términos estrictamente económicos).
- $ROI < 0$: inversión aún no rentabilizada (lo cual no implica que sea injustificada, especialmente en contextos regulatorios o de riesgos catastróficos de baja probabilidad).

Este enfoque puede refinarse incorporando:

- Probabilidad de incidentes graves (basada en datos externos o series históricas).
- Cálculos de pérdida esperada anual (ALE, Annual Loss Expectancy).
- Escenarios “antes/después” de determinadas medidas clave (Zero Trust, segmentación, etc.).

5. Visualización y reporting

Se recomienda incluir:

- Gráficos radar para T, R, I, K, E por organización.
- Histogramas de IGM por sector y tamaño.
- Gráficos de dispersión relacionando IGM con ROI_CS.

Estos elementos alimentan directamente la plantilla de reporte ejecutivo (véase `f_plantilla_reporte_ejecutivo_ppt.md`).

6. Nota de prudencia

Los cálculos propuestos no pretenden capturar toda la complejidad del riesgo cibernético, sino ofrecer una aproximación estructurada y comparable.

Los supuestos y pesos deben ser revisados por cada organización para ajustarse a su realidad y apetito de riesgo.